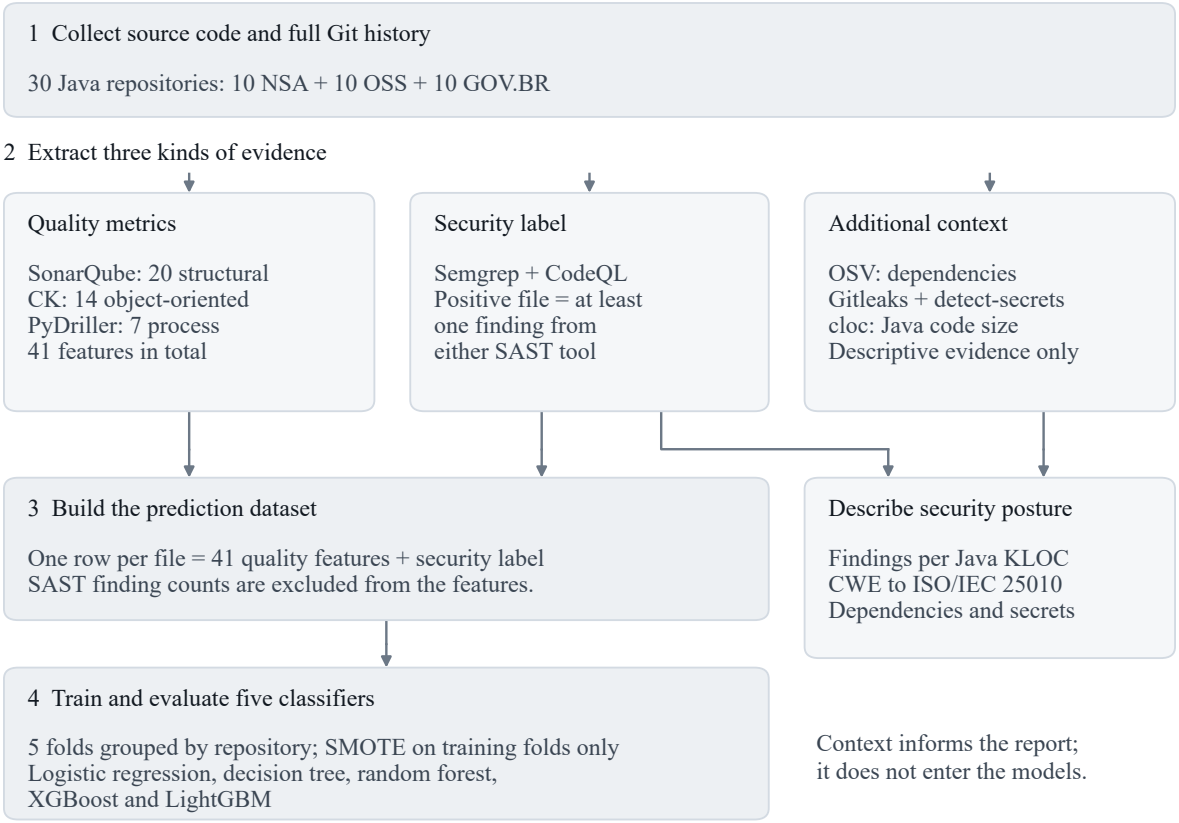
1 Collect source code and full Git history
30 Java repositories: 10 NSA + 10 OSS + 10 GOV.BR
2 Extract three kinds of evidence
Quality metrics
SonarQube: 20 structural
CK: 14 object-oriented
PyDriller: 7 process
41 features in total
Security label
Semgrep + CodeQL
Positive file = at least
one finding from
either SAST tool
Additional context
OSV: dependencies
Gitleaks + detect-secrets
cloc: Java code size
Descriptive evidence only
3 Build the prediction dataset
One row per file = 41 quality features + security label
SAST finding counts are excluded from the features.
Describe security posture
Findings per Java KLOC
CWE to ISO/IEC 25010
Dependencies and secrets
4 Train and evaluate five classifiers
5 folds grouped by repository; SMOTE on training folds only
Logistic regression, decision tree, random forest,
XGBoost and LightGBM
Context informs the report;
it does not enter the models.